

INSPER · AULA 07 · UNIDADE 3: MACHINE LEARNING APLICADO À SEGURANÇA

Como extrair padrões e anomalias de grandes volumes de *logs*?

*Detecção não supervisionada, Isolation Forest e
clustering para caçar o que ninguém rotulou*

DISCIPLINA

Cibersegurança Aplicada com IA

FORMATO

Aula expositiva · laboratório em duplas

```
aluno@insper:~$ python detecta.py  
aula7_logs_ssh.log  
7.914 linhas · 143 IPs de origem · 0 rótulos  
IsolationForest(contamination=0.02).fit(X)  
top-3 mais raros: 192.0.2.66 · 203.0.113.7 ·  
198.51.100.9
```

Roteiro de *hoje*

01 Do supervisionado ao não supervisionado

O que muda quando ninguém rotulou os dados

02 Anomalia e o problema do volume

Três tipos de anomalia e por que ler o log não escala

03 Do texto ao alerta

Parsing, agregação de eventos em entidades e engenharia de features

04 Os modelos de hoje

Isolation Forest, ranking por raridade e clustering como detector

05 Laboratório

Uma semana de logs SSH sem rótulos · em duplas · itens a) a h)

PONTE COM AS AULAS 5 E 6

O que muda a partir de *hoje*

AULAS 5 E 6 - SUPERVISIONADO

- ◆ Alguém **rotulou** cada exemplo: benigno ou ataque, e qual ataque
- ◆ O modelo aprende a **fronteira** entre classes conhecidas
- ◆ Avaliação direta: matriz de confusão contra o rótulo
- ◆ Limite: só detecta o que **já foi visto** e rotulado

HOJE - NÃO SUPERVISIONADO

- ◆ Ninguém rotulou nada. Só temos o **comportamento observado**
- ◆ O modelo aprende o que é **normal** e aponta o que foge disso
- ◆ Avaliação exige **investigação humana**: não há gabarito
- ◆ Potencial: pegar o ataque que **nunca foi visto** antes

POR QUE NÃO DÁ PARA LER

O problema é o *volume*

~8 mil

linhas de autenticação em um único servidor, em uma semana. É o arquivo do lab de hoje.

milhões

de eventos por dia em um SOC de médio porte, somando rede, endpoints e aplicações.

> 4 h

para um analista ler o arquivo do lab a 2 s por linha, sem pausa. Um servidor, uma semana.

*Ler não escala. Precisamos de **representação (features)** e de um modelo que priorize o que merece olhos humanos.*

DEFINIÇÕES

O que é uma *anomalia*?

DEFINIÇÃO

Um padrão nos dados que **não se conforma** com a noção estabelecida de comportamento normal (Chandola et al., 2009).

PONTUAL

Estranho por si só

Um evento é anômalo em qualquer contexto.

Ex.: 1.300 falhas de senha de um único IP em 25 minutos.

CONTEXTUAL

Estranho aqui

Seria normal em outro contexto, mas não neste.

Ex.: login às 3h de sábado numa conta que só opera às 2h via cron.

COLETIVA

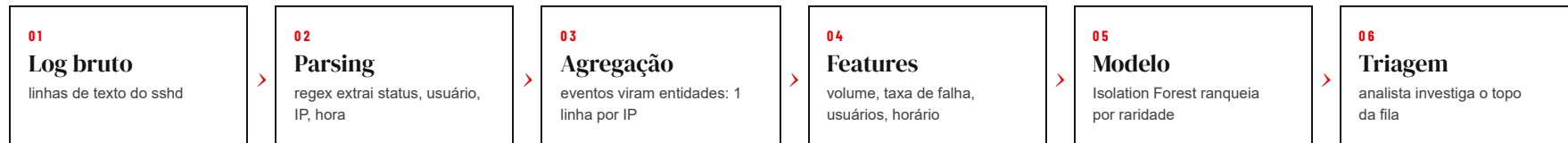
Estranho em conjunto

Cada evento isolado parece inofensivo; o conjunto denuncia.

Ex.: 2 falhas por usuário, em 48 usuários, do mesmo IP.

DO TEXTO AO ALERTA

O pipeline de hoje, de *ponta a ponta*



*A parte inteligente não é o modelo: é a passagem de **eventos para entidades** com boas features. O modelo só ordena o que a representação permitir enxergar.*

PARSING

Anatomia de uma linha do *auth.log*

```
Aug 25 14:02:37 srv-web01 sshd[8412]: Failed password for invalid user admin from 192.0.2.66 port 41022 ssh2
```

Quando

timestamp (**sem ano!**) e hora do dia

O quê

Accepted ou Failed · password
ou publickey

Quem

usuário alvo · a flag invalid
user importa

De onde

IP de origem: a entidade que
vamos agregar

REGEX COM GRUPOS NOMEADOS

(?P<status>Accepted|Failed) ... (?P<ip>\S+) — o notebook traz o padrão quase pronto.

AGREGAÇÃO E FEATURES

De eventos para *entidades*

O modelo não classifica linhas de log. Ele compara **entidades**: aqui, cada IP de origem vira uma linha com o resumo do comportamento da semana.

Volume

$\text{total_eventos} \cdot \text{pico_10min}$

Padrão de força bruta.

Resultado

$\text{n_falhas} \cdot \text{taxa_falha}$

Assinatura de scanner vs. usuário.

Alvos

$\text{n_usuarios} \cdot \text{n_invalidos}$

Varredura de muitas contas.

Tempo

$\text{frac_madrugada} \cdot \text{n_dias}$

Anomalia contextual no horário.

*Toda feature embute uma **hipótese** sobre o que é normal neste servidor. Não supervisionado não significa livre de hipóteses.*

O MODELO DE HOJE

Isolation Forest: a *intuição*

A PERGUNTA INVERTIDA

Em vez de modelar o que é normal, o algoritmo pergunta: **quão fácil é isolar este ponto** dos demais?

- ◆ Sorteia uma feature e um valor de corte, repetidamente, construindo uma **árvore aleatória**
- ◆ Pontos comuns, cercados de vizinhos, exigem **muitos cortes** até ficarem sozinhos
- ◆ Pontos raros ficam sozinhos com **poucos cortes**: caminho curto na árvore
- ◆ **Score = profundidade média** do ponto em centenas de árvores. Curto = anômalo

PONTO RARO

corte 1 · corte 2 → **isolado**

profundidade 2

PONTO COMUM

corte 1 · 2 · 3 · ... · 11 → separa

profundidade 11

USANDO O MODELO

Score, ranking e o parâmetro *contamination*

O QUE O MODELO ENTREGA

- ◆ Um **score contínuo** por entidade: quanto menor, mais anômalo
- ◆ O produto real é um **ranking**: uma fila de investigação ordenada por raridade, não um veredito binário

O QUE CONTAMINATION DECIDE

- ◆ Apenas **onde cortar a fila**: com 2%, os 2% piores scores recebem a flag de anômalo
- ◆ Não muda o ranking. É uma decisão operacional: **quantos alertas por dia** o time consegue investigar?

EM PRODUÇÃO

Quem escolhe esse número é **quem paga o custo da triagem**, não o algoritmo.

A ALTERNATIVA DO LAB

Clustering como *detector de anomalias*

K-MEANS

Longe do centro

Agrupa em **k** grupos; pontos longe do centro do próprio grupo são candidatos a anomalia.

Exige escolher **k** e sofre com grupos de formas irregulares.

DBSCAN

Ruído é suspeito

Agrupa por **densidade** e marca como ruído (**label -1**) o que não pertence a grupo nenhum.

Ruído é uma lista natural de suspeitos, sem escolher **k**.

A PEGADINHA

Escondido no cluster

Um atacante cujo perfil agregado se parece com um grupo grande e inofensivo **se esconde dentro do cluster**.

O que o diferencia pode pesar pouco na distância.

Ruído: fácil de listar. Escondido no cluster: difícil de ver. Nenhum método é gabarito.

Anomalia não *é ataque.*

Anomalia é raridade estatística. Ataque é um julgamento sobre intenção. O modelo entrega uma fila; **quem condena ou absolve é a investigação.**

- ◆ **Corolário 1** · Todo detector de anomalias produz falsos positivos: o usuário que digita mal a senha é raro e inocente.
- ◆ **Corolário 2** · Ataques deliberadamente comuns (low and slow) tentam não ser raros. A corrida armamentista continua.

MÃOS À OBRA

O laboratório de *hoje*

O cenário

Uma semana de logs de autenticação SSH do servidor **srv-web01**, sem nenhum rótulo. Nessa semana aconteceram coisas que não deveriam ter acontecido. **Encontrem**.

Arquivos

aula7_logs_ssh.log — o dataset
aula7_lab_deteccao_anomalias.ipynb — o notebook guiado
Mesma pasta, rodar célula a célula.

Formato

Em duplas, em sala. Três **TODOs** curtos de código e perguntas de interpretação ao longo do caminho. Itens a) até h).

Entrega da aula

Ao final: a lista de **IPs classificados como ataque**, com uma justificativa de uma frase para cada. Comparamos as listas na plenária.

MÉTODO, NÃO RESPOSTA

Como investigar um *IP suspeito*

1

Perfil

O que as features dizem? Volume, taxa de falha, quantos usuários, que horário?

2

Linha do tempo

Volte ao log bruto: como os eventos se distribuem? **Rajada** ou **gotejamento**?

3

Contexto

Isso é normal para **esta** entidade?
Um cron às 2h é normal; o mesmo login às 3h de sábado, não.

4

Veredito

Ataque (qual?), benigno estranho, ou **não sei**. Não sei é resposta profissional: vira caso de monitoramento.

*O método é o entregável, **não a resposta**. Duas duplas podem divergir e ambas estarem certas, se a justificativa estiver.*

FECHAMENTO

O que levar desta *aula*

- ◆ Sem rótulos, a abordagem se inverte: **modelamos a normalidade** e ranqueamos desvios.
 - ◆ A qualidade vem da **representação**: parsing e features carregam as hipóteses.
 - ◆ Isolation Forest e clustering enxergam anomalias diferentes; **nenhum é gabarito**.
 - ◆ Anomalia não é ataque: **o modelo prioriza, o analista julga**.
-

Próxima aula: e quando a classe que interessa é raríssima? Detecção de fraude e dados desbalanceados. • **Leitura:** Chio & Freeman, cap. 3 (*Anomaly Detection*), no acervo.